

XOLVON API

Dokumentasi REST API dan Postman Collection

Dokumen ini dibuat dari endpoint aktif di source code NestJS dan collection Postman proyek Xolvon. Tidak ada secret, password, API key, atau token yang disimpan di dokumen.

Versi	V1
Base URL lokal	{{baseUrl}} = http://localhost:3000/api
Format	JSON over HTTP
Autentikasi	Bearer JWT
Jumlah request Postman	66

1. Ringkasan Arsitektur

Backend menggunakan NestJS. Semua route memiliki global prefix **/api**. Validasi request memakai ValidationPipe dengan whitelist, forbidNonWhitelisted, dan transform. Respons error diproses oleh global exception filter tanpa stack trace internal.

Konvensi umum:

- Gunakan header **Content-Type: application/json** untuk request dengan body JSON.
- Endpoint terlindungi memakai **Authorization: Bearer {{accessToken}}**.
- Role user adalah role default. Endpoint admin memerlukan JWT dengan role admin.
- Pagination memakai **page** 1-based dan **limit** maksimal 100, default 20.
- Field yang tidak ada di DTO ditolak oleh server.
- Status order: pending, paid, cancelled. Status enrollment: active, revoked.

2. Setup Postman

Import file berikut ke Postman:

```
/Users/nabilkencana/Downloads/Documents/XOLVON PROJECT/Project-SaaS-Xolvon/Xolvon-API.postman_collection.json
```

Set collection variables berikut. Jalankan Login user atau Login admin sebelum endpoint private.

Variable	Nilai awal
baseUrl	http://localhost:3000/api
accessToken	(kosong)
refreshToken	(kosong)
email	user@example.com
password	Password123!
adminEmail	admin@example.com
adminPassword	Password123!
userId	00000000-0000-4000-8000-000000000000
courseId	00000000-0000-4000-8000-000000000000
courseSlug	contoh-course
lessonId	00000000-0000-4000-8000-000000000000
projectId	00000000-0000-4000-8000-000000000000
projectSlug	contoh-project
memberId	00000000-0000-4000-8000-000000000000
memberSlug	contoh-member
marketplaceId	00000000-0000-4000-8000-000000000000
marketplaceSlug	contoh-produk
orderId	00000000-0000-4000-8000-000000000000
enrollmentId	00000000-0000-4000-8000-000000000000
mediaId	00000000-0000-4000-8000-000000000000
resourceId	00000000-0000-4000-8000-000000000000

3. Alur Autentikasi

Urutan normal untuk pengujian:

- POST /auth/register untuk membuat user baru.
- POST /auth/login. Test script collection menyimpan accessToken dan refreshToken otomatis.
- Gunakan {{accessToken}} pada endpoint user atau admin.
- Jika access token kedaluwarsa, POST /auth/refresh lalu token baru disimpan otomatis.
- POST /auth/logout untuk mencabut refresh token.

Contoh login:

```
{
  "email": "{{email}}",
  "password": "{{password}}"
}
```

4. Daftar Endpoint Lengkap

Collection berisi 66 request yang dikelompokkan berdasarkan modul. Endpoint di bawah memakai base URL {{baseUrl}}.

00. Health & Public

Method	Request	Path
GET	Health check	{{baseUrl}}
Method	Request	Path
GET	Home aggregation	{{baseUrl}}/home
Method	Request	Path
GET	Search published content	{{baseUrl}}/search?q={{searchQuery}}&type={{searchType}}&page=1&limit=20

01. Auth

Method	Request	Path
POST	Register user	{{baseUrl}}/auth/register
Method	Request	Path
POST	Login user - save tokens	{{baseUrl}}/auth/login
Method	Request	Path
POST	Login admin - save tokens	{{baseUrl}}/auth/login
Method	Request	Path
GET	Current user	{{baseUrl}}/auth/me
Method	Request	Path
GET	Admin access check	{{baseUrl}}/auth/admin
Method	Request	Path
POST	Refresh access token	{{baseUrl}}/auth/refresh
Method	Request	Path
POST	Logout	{{baseUrl}}/auth/logout

02. Courses & Lessons

Method	Request	Path
GET	List published courses	{{baseUrl}}/courses?page=1&limit=20&sort=latest&q=

Method	Request	Path
GET	Get published course	{{baseUrl}}/courses/{{courseSlug}}
Method	Request	Path
POST	Admin create course	{{baseUrl}}/courses
Method	Request	Path
PATCH	Admin update course	{{baseUrl}}/courses/{{courseId}}
Method	Request	Path
POST	Publish course	{{baseUrl}}/courses/{{courseId}}/publish
Method	Request	Path
POST	Unpublish course	{{baseUrl}}/courses/{{courseId}}/unpublish
Method	Request	Path
GET	List course lessons	{{baseUrl}}/courses/{{courseSlug}}/lessons
Method	Request	Path
POST	Create lesson	{{baseUrl}}/courses/{{courseId}}/lessons
Method	Request	Path
PATCH	Update lesson	{{baseUrl}}/lessons/{{lessonId}}
Method	Request	Path
DELETE	Delete lesson	{{baseUrl}}/lessons/{{lessonId}}
Method	Request	Path
PATCH	Reorder lesson	{{baseUrl}}/lessons/{{lessonId}}/reorder
Method	Request	Path
POST	Publish lesson	{{baseUrl}}/lessons/{{lessonId}}/publish
Method	Request	Path
POST	Unpublish lesson	{{baseUrl}}/lessons/{{lessonId}}/unpublish
Method	Request	Path
GET	Get lesson video URL	{{baseUrl}}/lessons/{{lessonId}}/video-url
Method	Request	Path
POST	Create lesson resource	{{baseUrl}}/lessons/{{lessonId}}/resources
Method	Request	Path
DELETE	Delete lesson resource	{{baseUrl}}/resources/{{resourceId}}

03. Projects

Method	Request	Path
GET	List published projects	{{baseUrl}}/projects?page=1&limit=20&sort=latest&q=
Method	Request	Path
GET	Get published project	{{baseUrl}}/projects/{{projectSlug}}
Method	Request	Path
POST	Create project	{{baseUrl}}/projects
Method	Request	Path
PATCH	Update project	{{baseUrl}}/projects/{{projectId}}
Method	Request	Path
POST	Publish project	{{baseUrl}}/projects/{{projectId}}/publish

Method	Request	Path
POST	Unpublish project	{{baseUrl}}/projects/{{projectId}}/unpublish
Method	Request	Path
POST	Attach project media	{{baseUrl}}/projects/{{projectId}}/media
Method	Request	Path
DELETE	Detach project media	{{baseUrl}}/projects/{{projectId}}/media/{{mediaId}}
Method	Request	Path
POST	Assign project member	{{baseUrl}}/projects/{{projectId}}/members
Method	Request	Path
DELETE	Remove project member	{{baseUrl}}/projects/{{projectId}}/members/{{memberId}}

04. Collective

Method	Request	Path
GET	List published collective	{{baseUrl}}/collective?page=1&limit=20&q=
Method	Request	Path
GET	Get collective member	{{baseUrl}}/collective/{{memberSlug}}
Method	Request	Path
POST	Create collective member	{{baseUrl}}/collective
Method	Request	Path
PATCH	Update collective member	{{baseUrl}}/collective/{{memberId}}
Method	Request	Path
POST	Publish collective member	{{baseUrl}}/collective/{{memberId}}/publish
Method	Request	Path
POST	Unpublish collective member	{{baseUrl}}/collective/{{memberId}}/unpublish

05. Marketplace

Method	Request	Path
GET	List marketplace	{{baseUrl}}/marketplace?page=1&limit=20&sort=latest&q=
Method	Request	Path
GET	Get marketplace item	{{baseUrl}}/marketplace/{{marketplaceSlug}}
Method	Request	Path
POST	Create marketplace item	{{baseUrl}}/marketplace
Method	Request	Path
PATCH	Update marketplace item	{{baseUrl}}/marketplace/{{marketplaceId}}
Method	Request	Path
POST	Publish marketplace item	{{baseUrl}}/marketplace/{{marketplaceId}}/publish
Method	Request	Path
POST	Unpublish marketplace item	{{baseUrl}}/marketplace/{{marketplaceId}}/unpublish
Method	Request	Path
POST	Attach marketplace media	{{baseUrl}}/marketplace/{{marketplaceId}}/media
Method	Request	Path
DELETE	Detach marketplace media	{{baseUrl}}/marketplace/{{marketplaceId}}/media/{{mediaId}}

06. Orders & Learning

Method	Request	Path
POST	Checkout order	{{baseUrl}}/orders
Method	Request	Path
POST	Submit payment proof	{{baseUrl}}/orders/{{orderId}}/payment-proof
Method	Request	Path
PATCH	Verify order - admin	{{baseUrl}}/orders/{{orderId}}/verify
Method	Request	Path
POST	Activate order - admin	{{baseUrl}}/orders/{{orderId}}/activate
Method	Request	Path
POST	Cancel order - admin	{{baseUrl}}/orders/{{orderId}}/cancel
Method	Request	Path
GET	List my enrollments	{{baseUrl}}/enrollments/me
Method	Request	Path
PATCH	Revoke enrollment - admin	{{baseUrl}}/enrollments/{{enrollmentId}}/revoke
Method	Request	Path
POST	Update lesson progress	{{baseUrl}}/progress
Method	Request	Path
GET	List my progress	{{baseUrl}}/progress

07. Admin & Media

Method	Request	Path
GET	Admin overview	{{baseUrl}}/admin/overview
Method	Request	Path
GET	Admin list users	{{baseUrl}}/admin/users?page=1&limit=20&q=
Method	Request	Path
GET	Admin user detail	{{baseUrl}}/admin/users/{{userId}}
Method	Request	Path
GET	Admin list orders	{{baseUrl}}/admin/orders?page=1&limit=20&q=&status=
Method	Request	Path
POST	Create media upload URL	{{baseUrl}}/admin/media/upload-url
Method	Request	Path
POST	Confirm media upload	{{baseUrl}}/admin/media/confirm
Method	Request	Path
POST	Create private media read URL	{{baseUrl}}/admin/media/read-url

5. Contoh Payload Penting

Register user

```
{
  "name": "Xolvon User",
  "email": "user@example.com",
  "phone": "+6281234567890",
  "password": "Password123!"
}
```

Create course (admin)

```
{
  "title": "Course Contoh",
  "slug": "course-contoh",
  "description": "Deskripsi course.",
  "price": 150000,
  "thumbnailUrl": "https://example.com/thumb.webp"
}
```

Checkout order (user)

```
{
  "courseIds": ["000000000-0000-4000-8000-000000000000"],
  "notes": "Pembayaran via transfer."
}
```

Update progress (user)

```
{
  "lessonId": "000000000-0000-4000-8000-000000000000",
  "completed": true
}
```

Create media upload URL (admin)

```
{
  "prefix": "public/site",
  "contentType": "image/webp",
  "size": 102400,
  "filename": "hero.webp"
}
```

6. Keamanan dan Batasan

- Jangan masukkan JWT, password, API key, atau credential produksi ke collection yang dibagikan.
- Jangan mengirim field role saat register. Registrasi publik tidak dapat membuat admin.
- Object key media privat tidak boleh dipakai melalui endpoint public.
- Order dihitung server-side. Client tidak boleh dipercaya untuk mengirim total harga.
- Ownership order, enrollment, progress, dan video diverifikasi dari subject JWT untuk mencegah IDOR.
- Rate limit register dan login adalah 5 request per menit per IP.
- Gunakan HTTPS pada staging dan production.

7. Referensi File

- docs/api-contract.md
- src/main.ts
- Xolvon-API.postman_collection.json
- README.md

Dokumen ini adalah dokumentasi teknis untuk pengujian dan integrasi API. Response aktual dapat berbeda berdasarkan data database dan environment.

8. Matriks Akses Endpoint

Matriks berikut membantu tim frontend, QA, dan backend memahami batas akses setiap modul. Semua endpoint private menggunakan Bearer JWT. Endpoint bertanda admin membutuhkan JWT dengan role admin.

Modul	Public	User	Admin	Catatan
Health / Home / Search	GET	—	—	Published content only
Auth	register, login, refresh, logout	me	admin check	Login menyimpan token otomatis
Courses	list, detail, lessons	—	CRUD + publish	Draft tidak tampil public
Projects	list, detail	—	CRUD + media + members	Media public/private dibatasi
Collective	list, detail	—	CRUD + publish	Email/telepon tidak public
Marketplace	list, detail	—	CRUD + media + publish	Showcase; bukan checkout internal
Orders	—	checkout, proof	verify, activate, cancel	Ownership order wajib cocok JWT
Learning	—	enrollment, progress, video URL	revoke, lesson CRUD	Enrollment aktif diperlukan
Admin / Media	—	—	dashboard, users, orders, R2	Object key privat tidak public

9. Kontrak Validasi Request

Server menjalankan validasi DTO secara global. Request dengan field tambahan akan ditolak karena **forbidNonWhitelisted**. Gunakan tipe dan format berikut:

Field / Area	Aturan	Dampak jika salah
UUID resource	UUID v4 untuk courseId, lessonId, orderId, dan ID relasi	400 Bad Request
Slug	lowercase kebab-case, contoh: course-contoh	400 Bad Request
Email	Format email valid; dinormalisasi lowercase	400 Bad Request
Phone	8–20 karakter angka/spasi/symbol telepon	400 Bad Request
Price	Integer 0–1.000.000.000; total order dihitung server	400 atau total ditolak
Pagination	page 1-based; limit default 20, maksimum 100	400 Bad Request
Media	Content type dan prefix harus dari allowlist; size 1–524.288.000 byte	400 Bad Request
External URL	Marketplace memakai URL HTTPS valid	400 Bad Request

10. Alur Bisnis End-to-End

A. Pembelian course

- User login dan memperoleh access token.
- User melihat GET /courses dan memilih course published.
- User membuat POST /orders. Backend menghitung total berdasarkan database.
- User mengirim object key bukti pembayaran melalui POST /orders/:id/payment-proof.
- Admin memeriksa GET /admin/orders atau GET /admin/overview.
- Admin menjalankan PATCH /orders/:id/verify untuk mengubah pending menjadi paid.
- Admin menjalankan POST /orders/:id/activate untuk membuat enrollment aktif secara idempoten.
- User memeriksa GET /enrollments/me, mengambil video URL, lalu menyimpan progress.

B. Publikasi konten

- Admin membuat entitas dengan status draft.
- Admin melengkapi field wajib dan relasi media bila dibutuhkan.
- Admin menjalankan endpoint publish khusus.
- Frontend public membaca hanya endpoint published.
- Unpublish mengembalikan entitas ke draft tanpa menghapus data.

11. Standar Respons dan Error

Gunakan status HTTP sebagai sinyal utama. Body error diproses oleh `AllExceptionsFilter` dan tidak boleh dianggap sebagai sumber stack trace internal.

Status	Makna	Tindakan
200	Request berhasil	Baca response JSON
201	Resource berhasil dibuat	Simpan ID hasil response
400	DTO atau state transition tidak valid	Periksa body, UUID, slug, dan field ekstra
401	Token tidak ada atau tidak valid	Login ulang atau refresh token
403	Role tidak cukup	Gunakan akun admin untuk route admin
404	Resource tidak ditemukan atau tidak terlihat	Periksa ID/slug dan status published
409	Konflik state atau slug unik	Jangan retry tanpa memperbaiki state
429	Rate limit	Tunggu window reset; jangan spam retry
500	Kesalahan server	Simpan request ID jika ada dan cek log server

12. Runbook QA Postman

- Import collection dan pilih environment/local variables.
- Jalankan Health check. Pastikan server hidup sebelum testing bisnis.
- Register user hanya sekali per email. Jika sudah ada, langsung login.
- Login admin untuk menguji route admin. Jangan memakai token user pada route admin.
- Buat course/project/marketplace dalam status draft, lalu uji publish dan unpublish.
- Simpan ID dari response ke collection variables secara manual bila test script belum disediakan.
- Uji negative cases: body field ekstra, UUID invalid, slug uppercase, token kosong, role user ke admin route, dan object ID lintas user.
- Untuk setiap mutation, verifikasi response dan ulangi GET public/private yang relevan.
- Jangan menjalankan cancel, revoke, delete, atau unpublish terhadap data produksi tanpa fixture dan persetujuan.

13. Checklist Release

- CORS hanya mengizinkan origin environment terkait.
- JWT_SECRET memenuhi panjang minimum dan tidak masuk repository.
- Storage credentials hanya berada di environment server.
- Seed admin dijalankan terkontrol, bukan pada proses aplikasi normal.
- Rate limit login/register aktif.
- Security headers aktif melalui Helmet.
- Migration/database sudah siap pada environment target.
- Postman collection menggunakan placeholder, bukan credential nyata.
- Smoke test health, auth, public catalog, checkout, admin verification, dan enrollment lulus.